

Grade A Plus - Backend

Data Privacy, Security & Compliance

How the Grade A Plus backend stores school data, decides who may see it, and keeps it safe.

Contents

1. [What the Backend Is](#)
2. [The Journey of One Paper](#)
3. [Everything the Backend Does](#)
4. [The Data We Hold](#)
5. [Who Can See What](#)
6. [Signing In Safely](#)
7. [How AI Is Used on Student Work](#)
8. [Payments](#)
9. [A Record of Who Did What](#)
10. [Keeping and Removing Data](#)
11. [Defending the System](#)
12. [The Companies We Work With](#)
13. [How We Check Our Own Work](#)
14. [At a Glance](#)
15. [Reporting a Security Concern](#)

1. What the Backend Is

The backend is the part of Grade A Plus that users never see. The websites that teachers, students and school staff use are the front counter. The backend is everything behind it: the filing room, the marking desk, the accounts office and the security guard.

When a teacher opens a class or a student looks at a grade, the website asks the backend a question. The backend checks who is asking, decides what that person is allowed to see, and sends back only that. The websites hold no data of their own. Everything is kept, decided and recorded by the backend.

It has five standing jobs:

Job	What it means
Gatekeeper	Checks every single request and answers only with what that person is allowed to see
Record keeper	Holds accounts, classes, student work and the official record of every grade
Grading assistant	Reads student work with the help of AI and brings back a suggested grade for the teacher
Cashier	Works with our payment provider for subscriptions, school licences and grading credits
Witness	Keeps a permanent record of who did what, and when

The next two sections show those jobs in action. The rest of the document explains how each is done safely.

2. The Journey of One Paper

The clearest way to see what the backend does is to follow one piece of student work from start to finish.

1. **The teacher sets the work.** The teacher writes an assignment, or asks the AI to help draft the questions and a marking guide. The backend saves it against that teacher's class.
2. **The work comes in.** The teacher uploads the students' papers, one at a time or a whole class at once. The backend checks each file is a genuine PDF of an acceptable size.
3. **The paper is read.** The backend turns each page into a picture and asks the AI to read the answers, including handwriting. It matches the paper to the right student using the class list.
4. **The answers are marked.** The backend sends the answers and the teacher's marking guide to the AI, which suggests a score and written feedback for each question.
5. **The marking is double-checked.** A second AI gives an independent opinion. Where the two disagree, or where a page was hard to read, the backend flags the paper so the teacher knows to look closely.
6. **The teacher reviews.** The suggested grade goes to the teacher, not the student. The teacher can accept it, change it or ask for it to be marked again. The backend keeps the AI's original suggestion beside any change.

7. **The teacher releases the grade.** Only then can the student see it. The backend sends the student an email to say their grade is ready, if the student has an email address.
8. **Everything is recorded.** Each of these steps leaves an entry in the permanent activity record, and each use of AI is counted against the teacher's or school's grading credits.

The heavy work in steps 3 to 5 happens in the background. The teacher can carry on using the site, and the backend reports progress as each paper is finished.

3. Everything the Backend Does

Marking is the heart of the service, but the backend does a good deal more. Here is the full picture, in plain terms.

Accounts and sign-in

- Creates accounts for teachers, school administrators and students, and confirms email addresses.
- Signs people in with a password or with Google, and signs them out.
- Handles forgotten passwords with short-lived emailed codes.
- Sends invitations when a school adds a teacher or a teacher adds a student.

Schools, classes and students

- Keeps each school's list of teachers, and each teacher's school terms, courses and class lists.
- Adds students to a class one by one or from a whole list, and records when a student joins, completes or leaves a course.
- Moves a teacher into or out of a school, and adjusts what they can reach when that happens.

Assignments

- Stores each assignment with its questions, instructions and marking guide.
- Helps a teacher draft an assignment through a conversation with the AI.
- Produces a clean, printable PDF of an assignment for the classroom.
- Can start marking automatically when an assignment's due date arrives. It never releases grades automatically.

Marking and feedback

- Reads uploaded papers, marks them and double-checks the marking, as described in section 2.

- Works out each student's final grade for a course from their marked work.
- Writes a short summary of how a student is progressing, for the teacher.
- Remembers marking it has already done for an identical answer for a few days, so the same answer is marked the same way and no credit is spent twice.

Insight for teachers and schools

- Builds each teacher's dashboard: class averages, completion and which students may need help.
- Builds each school administrator's dashboard: results across the school, by course and by teacher.
- Writes weekly summaries for courses and for the school.
- Answers a teacher's or administrator's questions about their own figures through an AI assistant.

Payments, licences and credits

- Runs individual teacher subscriptions and school-wide licences with a set number of teacher seats.
- Records payments made by card and payments a school makes by invoice.
- Keeps a running account of grading credits: what was bought, what was granted to each teacher and what each piece of AI work used.
- Gives credit back when a piece of AI work fails.
- Handles renewals, cancellations, refunds and payment disputes.

Messages

- Sends the emails the service depends on: confirmations, invitations, password codes, grade notices and billing notices.
- Respects each person's notification choices.

Work done on a timetable

Some jobs run by themselves, every day or every few minutes, with nobody asking:

- Checking our billing records against the payment provider's, to catch any mismatch.
- Retiring grading credits that have reached their end date.
- Sending reminders before a subscription renews or a licence runs out.
- Removing old entries from the activity record once their keeping time is over.
- Checking its own health and raising an alert to our engineers if something is wrong.

Keeping watch

- Writes every important action into the permanent activity record.
- Reports faults to our engineers, with personal details left out.
- Measures the AI's marking against papers marked by hand, so we know how accurate it is.

4. The Data We Hold

We collect as little as we can. The less we hold, the less there is to protect.

What we hold

- **Teachers and school staff:** name, email address, school, and an optional profile picture.
- **Students:** name, the classes they are in, their answers, their grades and the feedback on their work.
- **Payments:** reference numbers, amounts and dates.

A student does not need an email address. A teacher can add a student by name alone, and no email is ever sent to a student added that way.

What we never hold

- **Sensitive facts about students.** We have no place to store a date of birth, gender, race, religion, disability, home address, phone number or parent details. The system was built without them.
- **Card numbers.** They go straight to our payment provider and never reach us.
- **Readable passwords.** Passwords are scrambled before they are stored, so nobody can read them back, including us.
- **Copies of scanned papers.** When a teacher uploads a scanned paper, we read the answers from it and keep the answers as text.

How it is stored

- The database is encrypted where it is stored.
- Everything travelling between a user and the backend is encrypted.
- The keys that let a user sign in with Google get a second layer of encryption of their own.

5. Who Can See What

There are four kinds of user. The backend decides what each one may see, and it decides again on every request.

Who	What the backend lets them see
Student	Their own courses and their own work. Grades and feedback appear only after the teacher releases them.
Teacher	Their own classes and the students in them. Nothing from another teacher's classes.
School administrator	Their own school only: its staff, its students and school-wide results. Never another school.
Grade A Plus support team	A small number of our own staff, with the access needed to run the service and help schools.

- **Nothing is shown without signing in.** The backend refuses any request that does not come from a signed-in user.
- **The backend never trusts the screen.** A web page may hide a button, but the backend makes the real decision. If someone got around a screen, the backend would still refuse.
- **One school cannot reach another's data.** Each answer is built only from that person's own school, classes or work.
- **Access ends when the job ends.** When a teacher leaves a school, they lose access to that school's classes.
- **The walls are tested.** Automatic tests try to cross these boundaries every time the software changes.

6. Signing In Safely

- **New accounts must confirm their email address** before they can be used.
- **Sessions are short-lived.** A sign-in lasts at most a day. It is renewed quietly in the background, and each renewal replaces the one before.
- **Signing out really signs you out.** Signing out or changing a password cancels every session on every device at once.

- **Wrong guesses lock the account.** Five wrong passwords in a row lock an account for fifteen minutes.
- **Reset codes expire quickly.** A password-reset code lasts fifteen minutes, and five wrong codes lock the reset for half an hour.
- **Each new student account gets its own password**, which must be changed the first time it is used.
- **Sign in with Google is checked by us**, not taken on trust.

Limits that stop automated guessing

The backend caps how often the same visitor can try a sensitive action. Without a cap, a program could keep trying thousands of times until something worked.

Action	Limit
Signing in	10 per minute
Asking for an emailed code	5 per hour
Creating an account	10 per hour
Signing in with Google	20 per hour

The limits hold even when someone tries to disguise where they are connecting from.

7. How AI Is Used on Student Work

- **The AI suggests; the teacher decides.** No grade reaches a student until a teacher releases it. Nothing is released automatically.
- **The marking step sees the work, not the person.** It uses only the answers and the teacher's marking guide. The student's name and email are not added to it.
- **The AI service is told not to keep or learn from student work.** Every request refuses any AI provider that would store the work or use it for training.
- **When the system is unsure, it says so.** Papers the AI could not read or grade with confidence are flagged for the teacher to check.
- **The original is always kept.** The AI's first grade is stored next to any change the teacher makes, so there is a record of both.

- **Names are used only where they are needed.** To match a scanned paper to the right student, the AI is shown the page and the class list of names. A written summary of a student's progress also uses their name.

8. Payments

- **We never see card details.** Cards are handled by Stripe, a trusted, PCI-compliant payment provider. Our servers receive only reference numbers.
- **Every message from the payment provider is verified** as genuine before the backend acts on it.
- **Real and test payments are kept apart.** Anywhere other than the live service, the backend uses test keys, so real payment data cannot leak into a test system.
- **Financial records cannot be rewritten.** Credit and billing entries can be added to, but the application cannot edit or delete them. The one exception is marking a payment as refunded.
- **There is an independent copy.** Every message from the payment provider is kept permanently, so billing history can always be checked against it.

9. A Record of Who Did What

The backend keeps a permanent activity record. It works like a visitor book that cannot be rewritten.

What it records

- Sign-ins, failed sign-ins and sign-outs
- Password changes and resets
- Grading, and every change to a grade
- Changes to class lists
- Payments, subscriptions and licence changes
- Changes to a person's role or access
- Everything our own support team does, including what they look at

How it is protected

- **Entries cannot be edited or deleted through the application.**
- **It holds reference numbers, not content.** It never stores a student's answers.

- **It protects students within the record itself.** A student's email address and location are never written into it.
- **It survives deletions.** Removing an account does not erase the record of what that account did.
- **A school administrator can review their own school's record** and no other school's.

10. Keeping and Removing Data

- **Teachers control their own classes.** A teacher can delete a class, an assignment or a student's paper. Deleting is permanent.
- **Removing a student from one class** leaves their work in other classes untouched.
- **An account can be deleted on request.** Our support team carries out a real, permanent delete that removes the person's work and class records.
- **Billing history is kept** after an account is deleted, because financial records must be.
- **A school that leaves is archived,** so nothing is lost by mistake.
- **The activity record is kept for a set time, then removed automatically:**

Kind of entry	Kept for
General activity	12 months
Entries about student grades and records	3 years
Network details attached to an entry	90 days

11. Defending the System

Against attacks from outside

- **Database attacks.** The backend never builds a database command out of text a user typed. That is the standard defence against the attack known as SQL injection.
- **Only our own websites may talk to the backend.** The list of allowed websites is fixed and contains only ours.
- **Uploads are checked.** A file is limited to 50 MB, and its contents must really be a PDF, whatever its name says.

- **Nothing internal is shown to users.** The mode that reveals technical error details is switched off on the live service.

Against our own mistakes

- **No secrets in the code.** Keys and passwords are kept outside the software, in the hosting environment.
- **No unsafe fallback.** If a required key is missing, the backend refuses to start.
- **Secrets are caught before they are saved.** Automatic checks stop a password or key from being saved into the code by mistake.
- **Error reports leave personal details out.** When something breaks, our engineers get a report that does not carry student work, grades or billing details.
- **System logs record reference numbers, not people.** Email addresses are scrubbed from the backend's internal logs.

12. The Companies We Work With

We use a small number of well-known companies. Each receives only what it needs for its job. We do not sell data to anyone.

Job	Company	What it receives
AI marking	OpenRouter	The work to be marked and the marking guide, with our instruction not to keep it
Payments	Stripe	The payer's name and email, and the card details they type in
Sending email	MailerSend, MailerLite	Email addresses and the messages we send
Sign in with Google	Google	Only what is needed to confirm who is signing in
Profile pictures	Cloudinary	Pictures users choose to upload
Error reports	Sentry	Technical details of faults, with personal details left out
Hosting	Railway	Runs the backend and its database

13. How We Check Our Own Work

- **More than 6,000 automatic tests** run against the whole backend before a release.
- **Every change is checked twice.** The person who writes a change is never the person who approves it.
- **We test the tests.** We deliberately break the code to confirm that a test notices.
- **We look for our own weaknesses.** We run regular security reviews, keep a written list of what we find, and fix the items in order of seriousness.
- **Changes are rehearsed first.** Every release is proven on a practice copy of the service before it reaches users.
- **Nothing reaches users without the founder's sign-off.**

14. At a Glance

Area	How the backend handles it
Encrypted connections	Required and enforced
Sign-in for every request	Enforced
Role-based access control	Decided by the backend on every request
Separation between schools	Enforced and tested
Password storage	Scrambled, never readable
Account lock after wrong passwords	Implemented
Limits on repeated attempts	Implemented
Session expiry and sign-out everywhere	Implemented
Student grades released only by a teacher	Enforced
AI service barred from keeping student work	Implemented
Card details	Never stored

Area	How the backend handles it
Financial records	Cannot be edited by the application
Audit logging	Permanent activity record
Secrets and keys	Kept outside the code, verified
Personal details in logs and error reports	Left out
Account deletion	Permanent, on request

15. Reporting a Security Concern

If you discover a security or privacy issue in Grade A Plus, please report it to the project maintainers privately. Please do not post details of an unpatched vulnerability publicly.

This document is a plain-language summary intended for a general audience. Detailed technical implementation notes are maintained separately for the engineering team.